

LAPORAN PENETRATION TESTING DVAPI

LAS WEEK 3 (CS)

MBC LAB 2026



NAMA: MUHAMMAD ILYAS SYARIEF

ID CAAS: 2644

DAFTAR ISI

DAFTAR ISI.....	2
1.INFORMASI UNUM.....	3
2.RINGKASAN CHALLENGE.....	3
3.DETAIL KERENTANAN PER CHALLENGE.....	4
4.RINGKASAN CVSS SCORES.....	14
5.TOOLS YANG DIGUNAKAN.....	15
6.KESIMPULAN.....	15

1. Informasi Umum

Item	Detail
Target	DVAPI (Damn Vulnerable API)
Platform	Node.js/Express + MongoDB
Port	3000
Base URL	http://localhost:3000
Tanggal Testing	2026-08-27
Framework Referensi	OWASP API Security Top 10 2023

2. Ringkasan Challenge

Penetesting DVAPI (Damn Vulnerable API) dilakukan untuk menguji 10 kerentanan yang ada di dalam list OWSAP API Security Top 10 2023. Semua kerentanan berhasil di eksploitasi dan mendapatkan flag yang berada di masing-masing challenge.

#	Challenge	OWASP API Top 10 2023	Status
1	API1: Broken Object Level Authorization	API1:2023	Solved
2	API2: Broken Authentication	API2:2023	Solved
3	API3: Broken Object Property Level Authorization	API3:2023	Solved
4	API4: Unrestricted Resource Consumption	API4:2023	Solved
5	API5: Broken Function Level Authorization	API5:2023	Solved
6	API6: Unrestricted Access to Sensitive Business Flows	API6:2023	Solved
7	API7: Server Side Request Forgery	API7:2023	Solved
8	API8: Security Misconfiguration	API8:2023	Solved
9	API9: Improper Inventory Management	API9:2023	Solved

10	API10: Unsafe Consumption of APIs	API10:2023	Solved
----	-----------------------------------	------------	--------

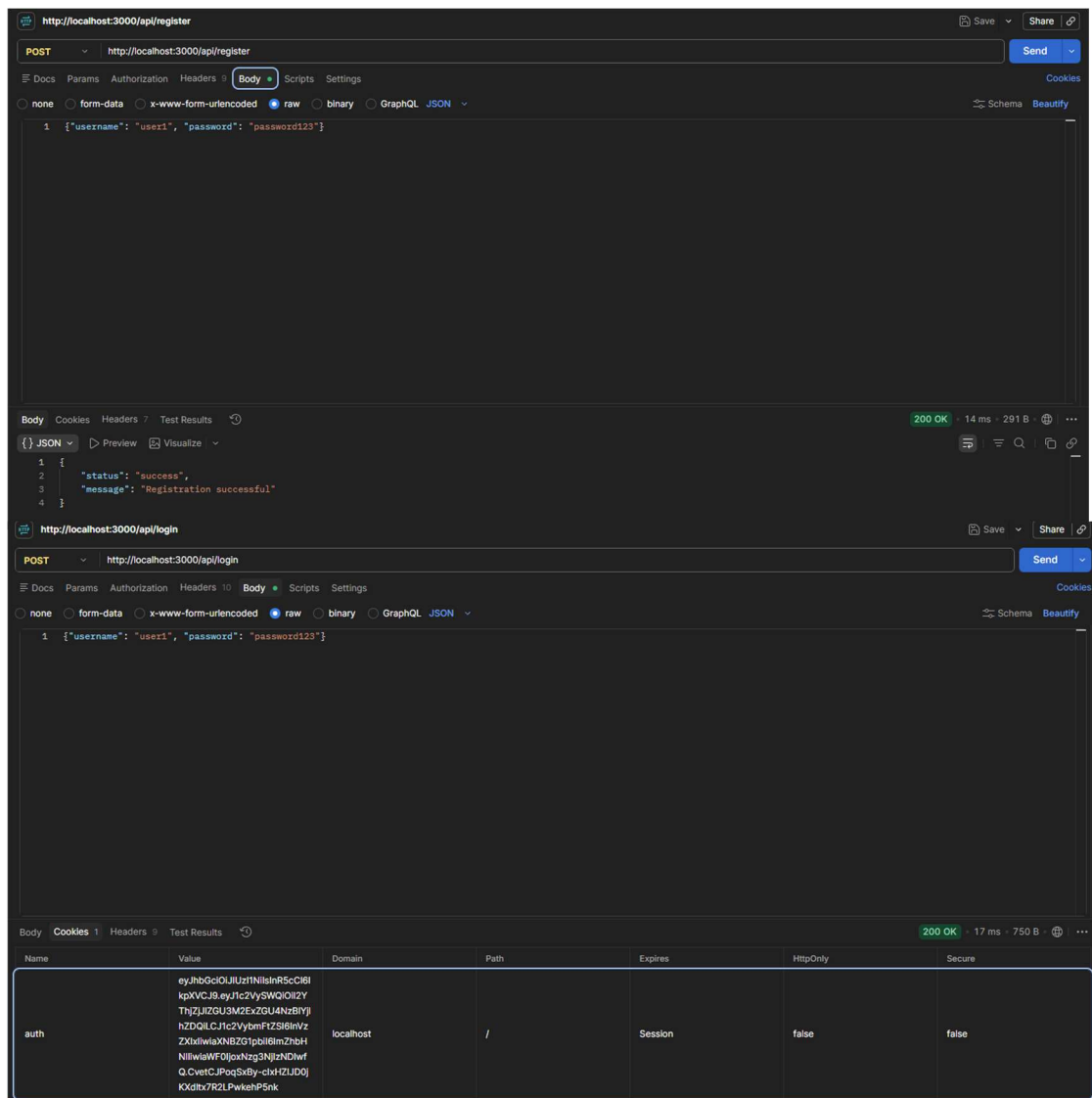
Total semua challenge atau kerentanan ada 10

3. Detail Kerentanan per Challenge

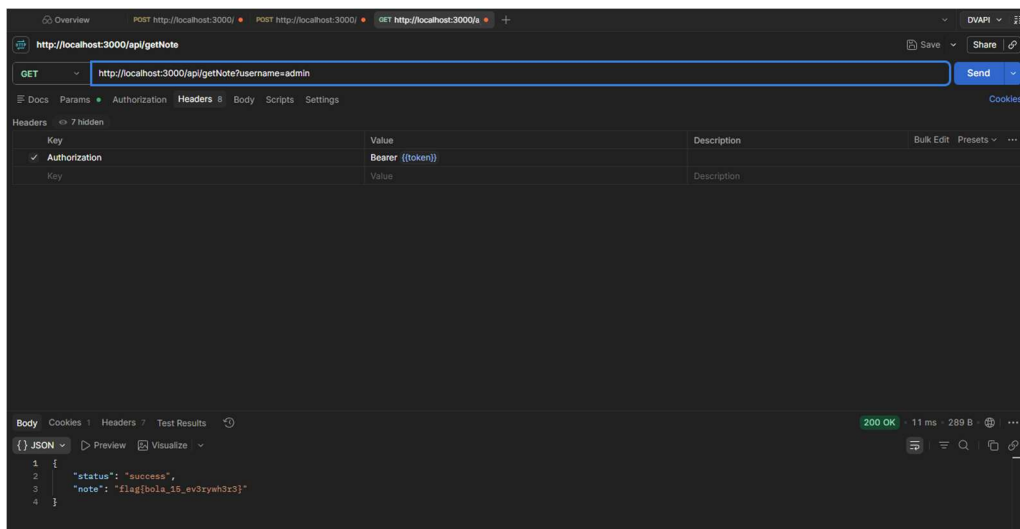
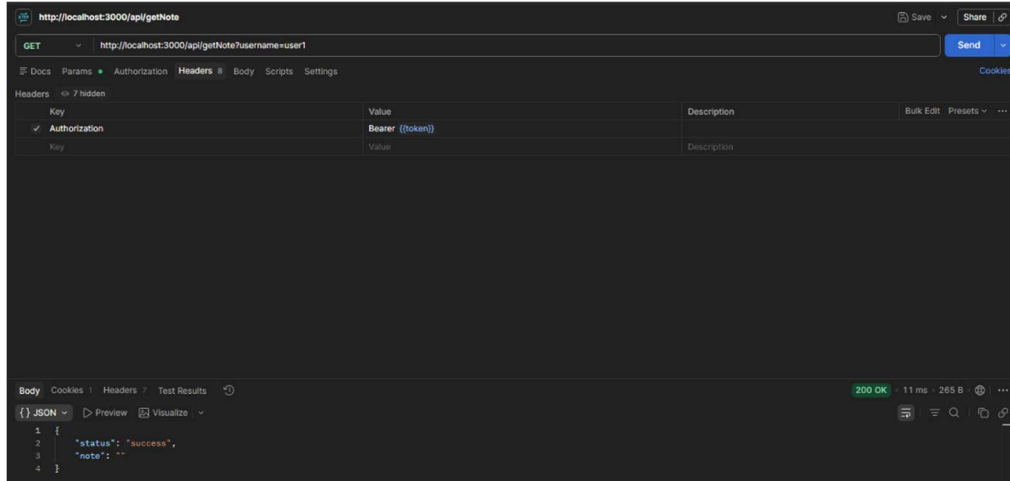
CHALLENGE 1: API1:2023 - Broken Object Level Authorization (BOLA):

Untuk melakukan eksploitasi, pertama-tama register dan login akun baru:

Untuk tools yang di gunakan adalah postman dengan menggunakan POST <http://localhost:3000/api/register> untuk registrasi akun dan POST <http://localhost:3000/api/login> untuk login ke akun yang baru di daftar



Kemudian di Endpoint `getNote` menerima parameter `username` dari query string tanpa memvalidasi apakah user yang request berhak mengakses data user tersebut. Di dalam pengujian awalnya menggunakan `getNote` user biasa GET <http://localhost:3000/api/getNote?username=user1> tapi karena tidak di validasi maka bisa akses GET <http://localhost:3000/api/getNote?username=admin>



dan dapat flag: `{bola_15_ev3rywh3r3}`

Dampak:

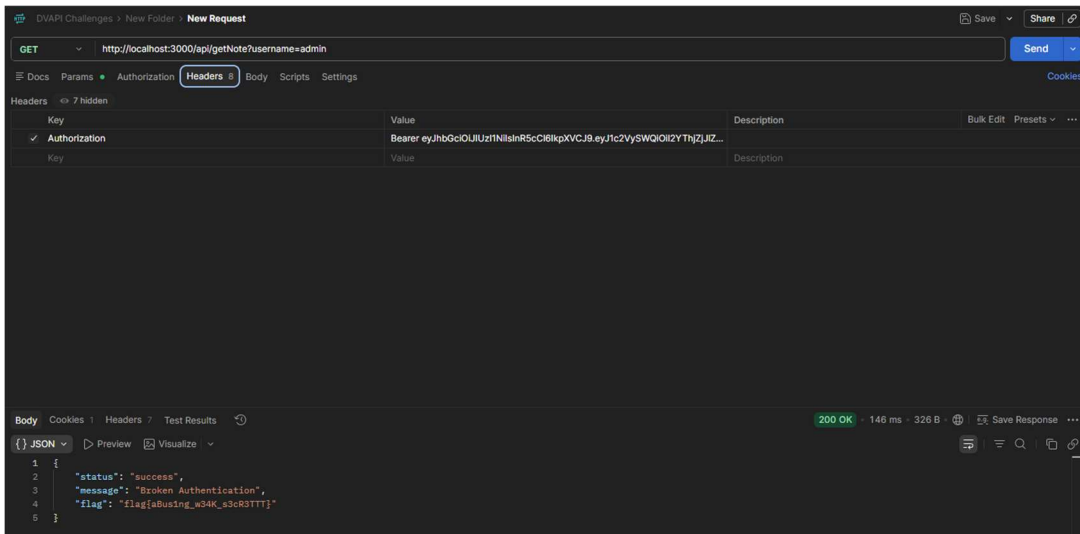
- CVSS 3.1: 6.5 (Medium) -
CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
- Kebocoran data sensitif user lain
- Pelanggaran terhadap least privilege

Mitigasi:

- Implementasi authorization check: pastikan req.user.id match dengan resource owner
- Gunakan object-level authorization middleware
- Jangan percaya input user untuk resource identifier

CHALLENGE 2: API2:2023 - Broken Authentication:

Untuk eksploitasi tahap ini adalah, mengubah atau mengedit JWT token user yang sudah ada menjadi token untuk admin



Flag: flag{aBus1ng_w34K_s3cR3TTT}

Dampak:

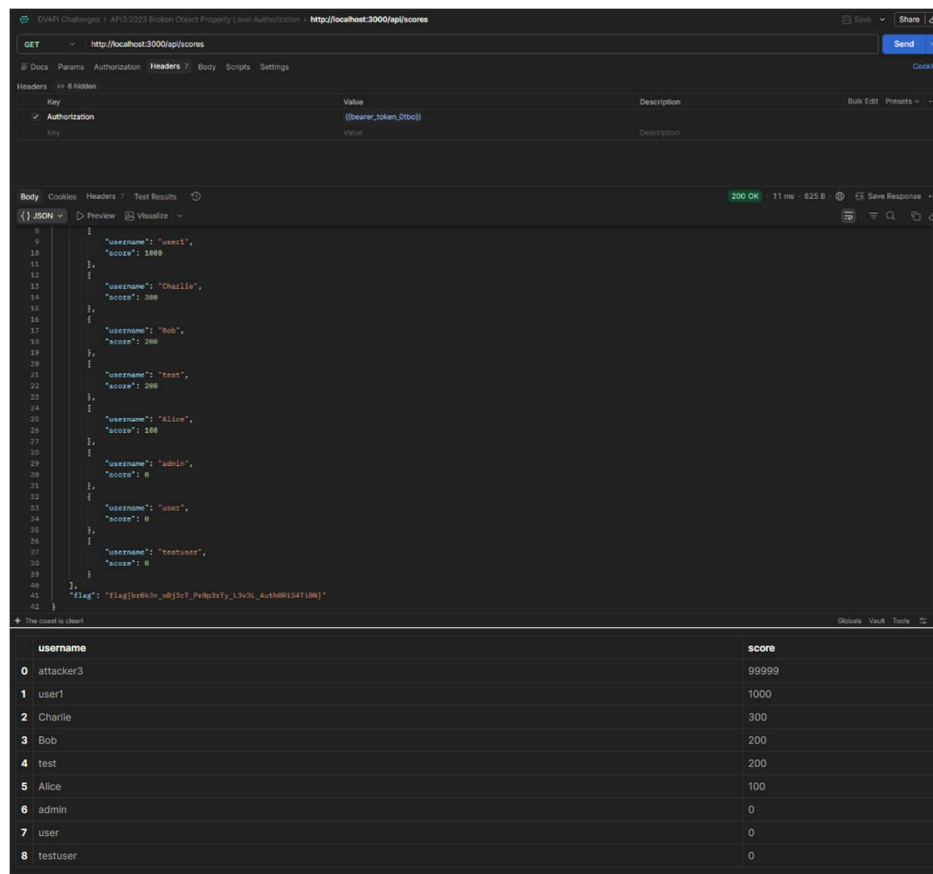
- **CVSS 3.1:** 8.8 (High) - CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
- Account takeover admin
- Bypass autentikasi sepenuhnya
- Akses penuh ke fungsi administrasi

Mitigasi:

- Hapus default credentials, enforce password policy kuat
- Gunakan JWT secret yang kuat
- Implementasi rate limiting & account lockout
- Tambahkan MFA untuk admin
- Set token expiry singkat (15-30 menit) + refresh token

CHALLENGE 3: API3:2023 - Broken Object Property Level Authorization:

Manipulasi score menggunakan getScore atau akses parameter allChallenges, mengubah score user attacker3 menjadi 99999



```
GET http://localhost:3000/api/score
```

Headers: Authorization: (bearer_token_0b0c)

Body (JSON):

```
{
  "username": "user1",
  "score": 1000
},
{
  "username": "Charlie",
  "score": 300
},
{
  "username": "Bob",
  "score": 200
},
{
  "username": "test",
  "score": 200
},
{
  "username": "Alice",
  "score": 100
},
{
  "username": "admin",
  "score": 0
},
{
  "username": "user",
  "score": 0
},
{
  "username": "testuser",
  "score": 0
},
{
  "flag": "flag{br0k3n_0bj3cT_Pr0p3rTy_L3v3L_Auth0RiS4Ti0N}"
}
```

username	score
0 attacker3	99999
1 user1	1000
2 Charlie	300
3 Bob	200
4 test	200
5 Alice	100
6 admin	0
7 user	0
8 testuser	0

Flag: flag{br0k3n_0bj3cT_Pr0p3rTy_L3v3L_Auth0RiS4Ti0N}

Dampak:

- CVSS 3.1: 7.1 (High) -
CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N
- Privilege escalation via score manipulation
- Akses challenge tersembunyi/unreleased
- Bypass business logic

Mitigasi:

- Implementasi allowlist field yang boleh di-update (deny list bukan solusi)
- Gunakan DTO/Validation schema yang strict

- Pisahkan object untuk input vs internal state
- Authorization check pada property level

CHALLENGE 4: API4:2023 - Unrestricted Resource Consumption:

Mengupload file atau dokumen yang memiliki file sebesar >50MB dan dapat menyebabkan DoS

```
~ Ilyas@HyperX mnt/.../Week 3 >$ curl -X POST http://localhost:3000/api/profile/upload \
-H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2V5SWQ1OiI2YThjZjJLZGU3M2ExZGU4NzBhYjZlZDQ1LCJ1c2VybWZlZSI6InVzZXIiOiwiXzB2G1pbiI6ImZhbnHwIiwiaWF0IjoxNzgzNjUwMDM0fQ.
Gwy2h-0YVN3sJLpD89oY-Ikp_1Wq4L2uQoTgcRNPFeY" \
-F "file=@mnt/d/Cyber_Security/Rekrutasi_MBC/LAS/Week_3/big.jpg"
{"message":"File uploaded successfully","profilePic":"6a8cf2ede73a1de870eb9ad4.jpg","size":"250.00 MB","flag":"flag{file_size_is_important}"}
```

Flag: flag{file_size_is_important}

Dampak:

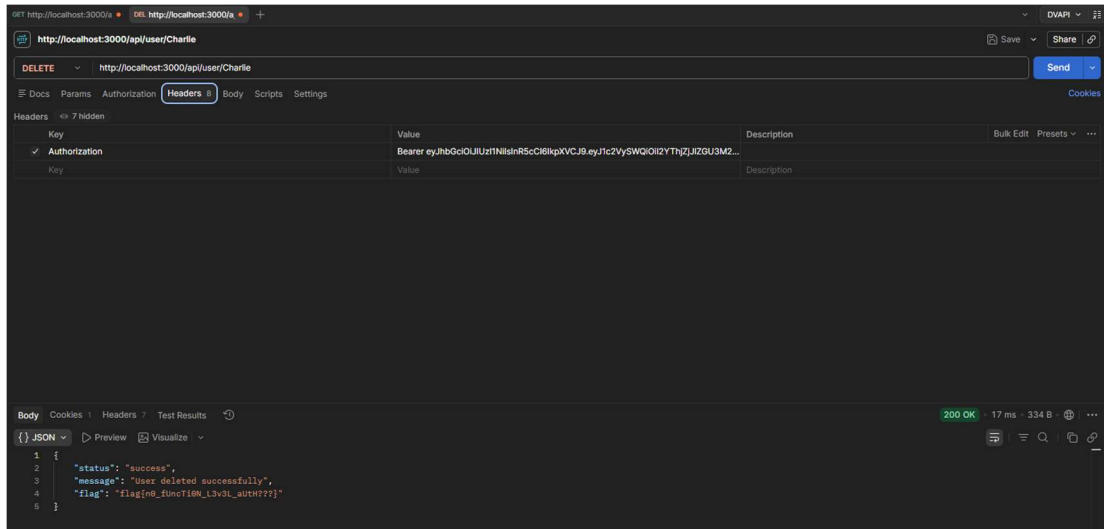
- **CVSS 3.1: 7.5 (High)** -
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
- Denial of Service via disk exhaustion
- Memory exhaustion saat processing file besar
- Biaya infrastruktur bertambah (bandwidth, storage)

Mitigasi:

- Batasi ukuran file maksimal (misal: 5MB)
- Validasi MIME type & extension
- Gunakan streaming upload, jangan load full ke memory
- Implementasi rate limiting per user/IP
- Gunakan cloud storage dengan quota (S3, GCS)
- Timeout upload & processing

CHALLENGE 5: API5:2023 - Broken Function Level Authorization:

Akses user admin bisa di gunakan oleh user biasa, sebagai contoh bisa untuk menghapus user lain, dan tidak diperiksa apakah yang hapus itu benar benar dari admin atau bukan.



Flag: flag{n0_fUncTi0N_L3v3L_aUth???

Dampak:

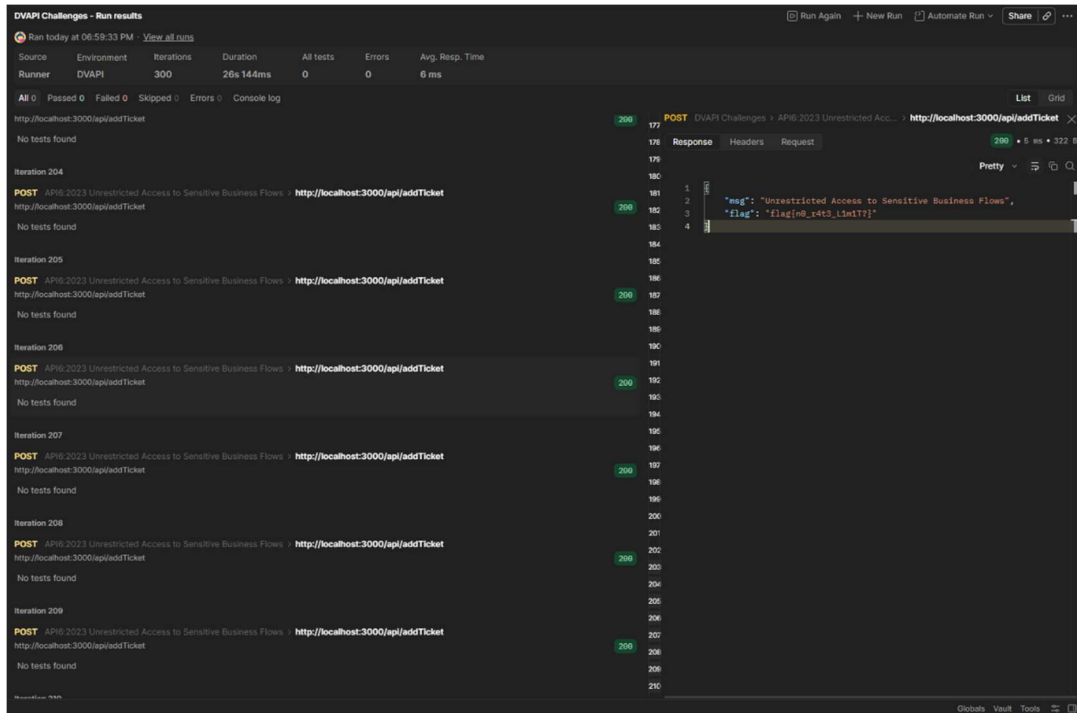
- **CVSS** **3.1:** **8.1** (High) -
CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
- User enumeration
- Account deletion oleh user biasa (privilege escalation)
- Data integrity violation

Mitigasi:

- Implementasi RBAC (Role-Based Access Control)
- Middleware requireAdmin() untuk endpoint sensitif
- Ownership check: req.user.id === resource.ownerId
- Audit logging untuk fungsi administratif

CHALLENGE 6: API6:2023 - Unrestricted Access to Sensitive Business Flows:

Otomatisasi pembuatan ticket >150 kali dalam hanya beberapa detik



Flag: flag{n0_r4t3_L1m1T?}

Dampak:

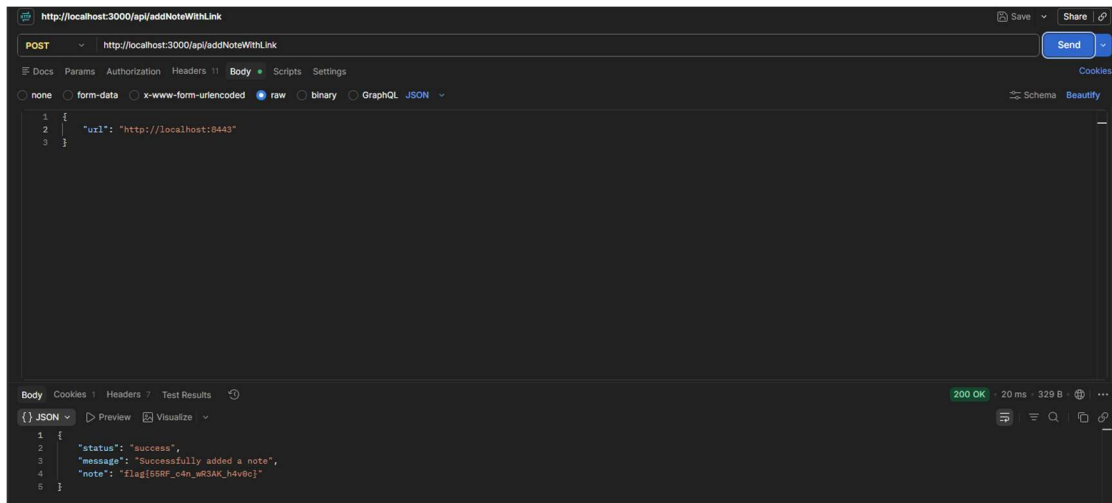
- CVSS 3.1: 6.5 (Medium)
- CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:L
- Abuse business logic (ticket spam)
- Bypass rate limit via race condition
- Resource exhaustion

Mitigasi:

- Rate limiting ketat per user/IP (misal: 5 ticket/jam)
- CAPTCHA untuk aksi sensitif
- Device fingerprinting
- Analisis pola non-human (kecepatan request, header)
- Queue system dengan throttling

CHALLENGE 7: API7:2023 - Server Side Request Forgery (SSRF):

Mengakses Endpoint addNoteWithLink melakukan HTTP request ke URL user-supplied tanpa validasi



Flag: flag{55RF_c4n_wR3AK_h4v0c}

Dampak:

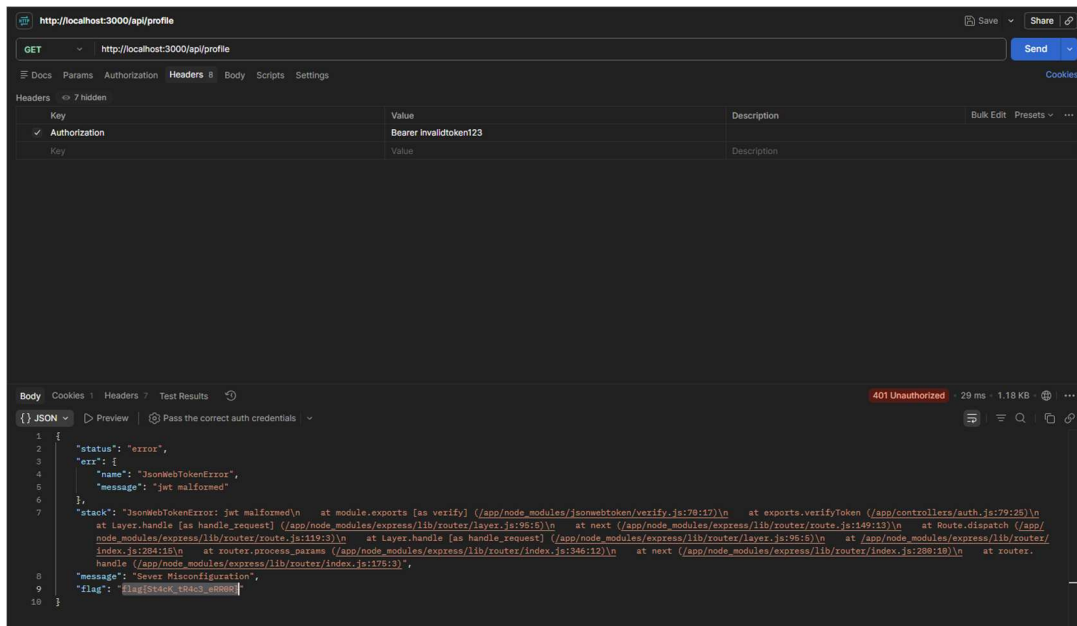
- CVSS 3.1: 8.6 (High) -
CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N
- Akses internal service (metadata cloud, database, admin panel)
- Port scanning internal network
- Bypass firewall/VPN
- Potensi RCE via internal endpoints

Mitigasi:

- Allowlist domain/IP yang diizinkan
- Block private IP ranges (10.x, 172.16-31.x, 192.168.x, 169.254.x, 127.x)
- Disable HTTP redirect following
- Timeout ketat (5 detik)
- Network segmentation (service mesh, egress proxy)
- Validasi URL schema (hanya https://allowed-domain.com)

CHALLENGE 8: API8:2023 - Security Misconfiguration:

Mentrigger error dengan token jwt yang invalid/tampered, atau akses endpoint tanpa parameter yang required



Flag: `flag{St4cK_tR4c3_eRR0R}`

Dampak:

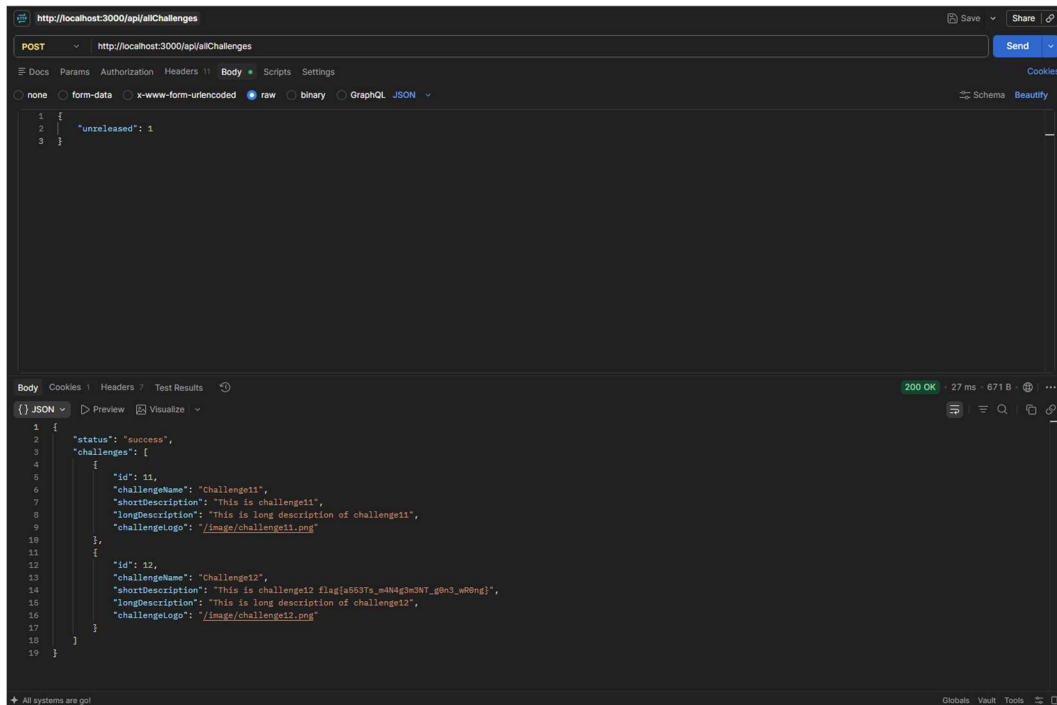
- CVSS 3.1: 7.5 (High) -
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
- Information disclosure (stack trace, internal logic, flags)
- Membantu attacker memahami arsitektur & mencari bug lain
- Compliance violation (PCI DSS, GDPR)

Mitigasi:

- Generic error message di production (no stack trace)
- Log error detail di server-side, tidak di response client
- Disable debug mode di production
- Custom error pages
- Security headers (X-Content-Type-Options, X-Frame-Options)

CHALLENGE 9: API9:2023 - Improper Inventory Management:

Mengakses endpoint/versi API tersembunyi (unreleased challenges)



Flag: flag{a553Ts_m4N4g3m3NT_g0n3_wR0ng}

Dampak:

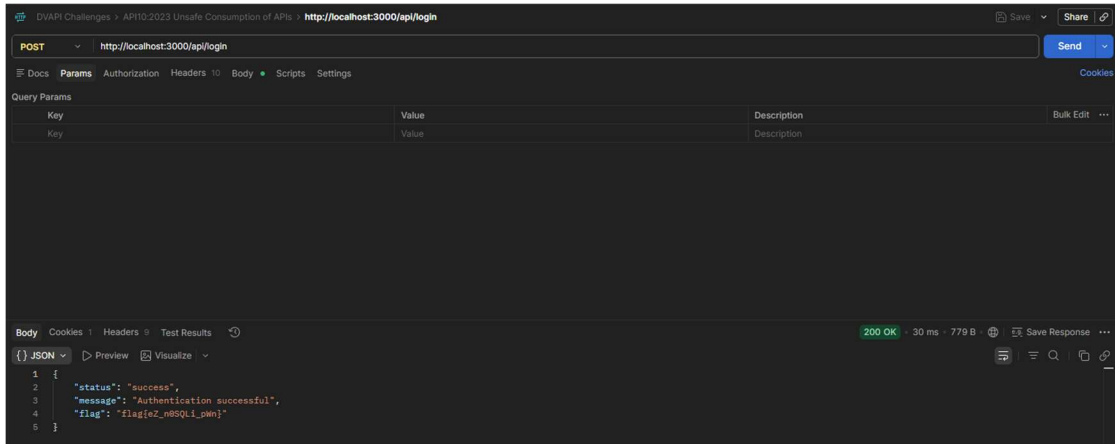
- CVSS 3.1: 5.3 (Medium) -
CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N
- Information disclosure (fitur rahasia, endpoint tersembunyi)
- Attack surface expansion
- Compliance risk (undocumented endpoints)

Mitigasi:

- API versioning & lifecycle management
- Inventory semua endpoint (Swagger/OpenAPI spec updated)
- Decommission endpoint lama dengan benar (410 Gone)
- Feature flag server-side, bukan client-controlled
- Automated API discovery & documentation

CHALLENGE 10: API10:2023 - Unsafe Consumption of APIs:

Trusting internal API tanpa validasi, dan login sebagai admin
- endpoint mempercayai internal logic tanpa validasi tambahan



Flag: flag{eZ_n0SQLi_pWn}

Dampak:

- CVSS 3.1: 7.4 (High) -
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
- Key exposure via response
- Crypto implementation flaw
- Trust boundary violation

Mitigasi:

- Validasi & sanitasi semua data dari third-party/internal APIs
- Jangan expose internal crypto operations via API response
- Gunakan HSM/Key Management System untuk key storage
- Implementasi zero-trust architecture
- Audit dependencies & third-party integrations

4. Ringkasan CVSS Scores

Challenge	CVSS v3 Score	Severity	Vector
API1: BOLA	6.5	Medium	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
API2: Broken Auth	8.8	High	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

API3: Property Auth	7.1	High	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N
API4: Resource Consumption	7.5	High	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
API5: Function Auth	8.1	High	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
API6: Business Flows	6.5	Medium	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:L
API7: SSRF	8.6	High	AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N
API8: Misconfiguration	7.5	High	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
API9: Inventory Mgmt	5.3	Medium	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N
API10: Unsafe API Consumption	7.4	High	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

5. Tools yang Digunakan

Tool	Kegunaan
Curl dan Postman	HTTP client untuk eksekusi request API
Docker	Menjalankan container DVAPI & MongoDB
Browser DevTools	Inspect network, localStorage, cookies
JWT.io	Decode & analisis JWT token
PowerShell	Scripting otomatisasi request
docker exec	Inspeksi source code di container

6. Kesimpulan

DVAPI memiliki 10 kerentanan yang mencakup seluruh OWASP API Security Top 10 2023. Temuan paling berbahaya adalah Broken Authentication (API2), Broken Function Level Authorization (API5), dan SSRF (API7) dengan skor CVSS > 8.0.

Semua kerentanan bersifat exploitable secara remote tanpa autentikasi khusus (kecuali butuh user account biasa), menunjukkan perlunya defense-in-depth di layer API.